MATRIZ DE REFERENCIAS NORMATIVAS Y MARCOS

Operación Trazabilidad · Paso 9 · Actualizada con el expediente disponible al 08/11/2026

Las referencias se utilizan como criterios orientadores. Su inclusión no demuestra aplicabilidad legal, certificación ni incumplimiento. La aplicabilidad debe verificarse según los hechos y el alcance de RedNova.

Matriz normativa

OPERACIÓN TRAZABILIDAD – MATRIZ DE REFERENCIAS NORMATIVAS Y MARCOS							
Paso 9 · Referencias para orientar la evaluación. La inclusión de una referencia no significa que RedNova esté certificada ni que exista incumplimiento.							
ITAF, 5.ª edición	Marco profesional de auditoría TI	ISACA; 5.ª edición (2026)	Establece estándares profesionales y guía para planificar, ejecutar y reportar auditorías de TI.	Sirve de referencia para documentar alcance, independencia, evidencia suficiente, procedimientos, conclusiones y reporte.	Aplicarlo al diseño y revisión de los papeles de trabajo PT-01 a PT-10, cadena de custodia y conclusiones. Comprobar que cada conclusión esté respaldada por evidencia.	Marco profesional; no es una ley guatemalteca ni una certificación de RedNova.	https://www.isaca.org/resources/it-audit
COBIT 2019	Marco de gobierno y gestión de TI	ISACA; COBIT 2019	Organiza objetivos de gobierno y gestión de información y tecnología, con enfoque en valor, riesgo y recursos.	Apoya la revisión de gobierno de TI, gestión de riesgos, cambios, proveedores, continuidad y responsabilidades.	Usarlo como criterio de referencia para revisar responsabilidades, gestión de cambios, riesgos de TI, supervisión de terceros y seguimiento de acciones.	Marco de buenas prácticas; seleccionar objetivos pertinentes, no declarar cumplimiento integral sin evaluación.	https://www.isaca.org/en/resources/cobit
ISO/IEC 27001:2022	Norma internacional de gestión de seguridad	ISO/IEC 27001:2022; enmienda 1:2024	Define requisitos para establecer, mantener y mejorar un sistema de gestión de seguridad de la información basado en riesgos.	Se relaciona con gestión de riesgos, controles de acceso, protección de información, proveedores, incidentes y continuidad.	Usarla como referencia para evaluar si existen políticas, evaluación de riesgos, responsabilidades, controles y mejora continua relacionados con el incidente.	No afirmar que RedNova está certificada ni que incumple la norma; la auditoría académica solo compara prácticas seleccionadas.	https://www.iso.org/standard/27001
NIST Cybersecurity Framework (CSF) 2.0	Marco de gestión de ciberseguridad	NIST CSF 2.0; febrero de 2024	Organiza resultados de ciberseguridad en seis funciones: Govern, Identify, Protect, Detect, Respond y Recover.	Permite ordenar los riesgos y controles de RedNova desde gobierno hasta recuperación.	Mapear hallazgos y acciones a las seis funciones: gobierno y terceros; activos y riesgos; accesos; monitoreo; respuesta; recuperación.	Marco voluntario y flexible; no prescribe por sí solo controles obligatorios ni constituye ley.	https://www.nist.gov/cyberframework
NIST SP 800-61 Rev. 3	Guía de respuesta a incidentes	NIST; revisión 3, abril de 2025	Integra la respuesta a incidentes dentro de la gestión de riesgos de ciberseguridad y se alinea con CSF 2.0.	Aplica a preservación de evidencia, análisis, contención, comunicación, recuperación y mejora posterior.	Usarla para revisar la cronología, escalamiento de alertas, preservación de registros, coordinación de respuesta y recuperación.	Guía técnica; reemplaza SP 800-61 Rev. 2. No tratar la revisión 2 como versión vigente.	https://csrc.nist.gov/pubs/sp/800/61/r3/final
OWASP Top 10:2025	Referencia de riesgos de aplicaciones web	OWASP Top 10; edición 2025	Resume riesgos importantes en aplicaciones web, incluidos control de acceso, configuración, cadena de suministro, criptografía, inyección, autenticación y registro.	Es pertinente para CRM, API e integraciones que participan en el incidente.	Tomarlo como guía para orientar pruebas de acceso, autenticación, configuración, integridad, registros y seguridad de API; relacionar pruebas con el programa de auditoría.	Documento de concienciación y referencia; no sustituye una prueba técnica ni representa por sí solo un estándar de certificación.	https://top10.owasp.org/2025/es/
NIST AI RMF 1.0 y NIST AI 600-1	Marco de riesgos de IA y perfil de IA generativa	NIST AI RMF 1.0 (2023); perfil de IA generativa AI 600-1 (2024)	Proporciona orientación voluntaria para gestionar riesgos de confiabilidad y uso de IA durante diseño, desarrollo, uso y evaluación; AI 600-1 amplía el análisis para IA generativa.	Aplica a la evaluación del chatbot: privacidad, exactitud, trazabilidad, supervisión humana, entradas maliciosas y exposición de información.	Usarlo para estructurar la evaluación del chatbot, revisar datos de entrada/salida, controles de acceso, registros, evaluación de respuestas y supervisión humana.	Marco voluntario. No asumir que el chatbot es generativo hasta confirmar su arquitectura y tipo de modelo.	https://www.nist.gov/itl/ai-risk-management-framework ; https://www.nist.gov/publications/artificial-intelligence-risk-management-framework-generative-artificial-intelligence
Constitución Política de Guatemala, artículo 24	Norma jurídica nacional	Constitución Política de la República de Guatemala; artículo 24	Reconoce la inviolabilidad de correspondencia, documentos y libros, y el secreto de las comunicaciones en los términos constitucionales.	Es una referencia para tratar con cuidado correos, documentos, registros y comunicaciones obtenidos durante la auditoría.	Considerar el artículo al definir acceso, revisión, preservación y divulgación de comunicaciones y documentos. Documentar autorización y alcance de las revisiones.	La aplicación concreta depende de los hechos y del procedimiento legal correspondiente; no afirmar automáticamente que ocurrió una violación.	https://www.congreso.gob.gt/assets/uploads/secciones/pdf/16e67-constitucion-politica-de-la-republica-de-guatemala.pdf
Ley de Acceso a la Información Pública, Decreto 57-2008	Ley nacional; aplicabilidad condicionada	Congreso de Guatemala; Decreto 57-2008; artículos 6 y 30, entre otros	Regula el acceso a información pública y obligaciones de sujetos obligados; incluye disposiciones sobre datos personales y hábeas data.	Puede ser relevante si la entidad auditada es sujeto obligado, administra recursos públicos o encaja en los supuestos legales aplicables.	Primero determinar si RedNova cumple la condición de sujeto obligado. Si aplica, revisar tratamiento, exactitud, finalidad, seguridad y atención de solicitudes sobre datos personales.	No asumir que aplica automáticamente a toda empresa privada. El caso debe confirmar la naturaleza jurídica y relación con fondos o funciones públicas.	https://www.congreso.gob.gt/detalle_pdf/decretos/13082
Ley para el Reconocimiento de las Comunicaciones y Firmas Electrónicas, Decreto 47-2008	Ley nacional sobre comunicaciones y firmas electrónicas	Congreso de Guatemala; Decreto 47-2008	Regula el reconocimiento jurídico de comunicaciones, transacciones y firmas electrónicas, con el ámbito y excepciones previstos en la ley.	Puede relacionarse con órdenes electrónicas, registros de transacciones, aprobaciones y evidencia de autorizaciones digitales.	Considerar su ámbito al evaluar contratos, aprobaciones, registros y firmas electrónicas; verificar autenticidad e integridad de los documentos electrónicos.	No es una ley integral de protección de datos ni una norma general de ciberseguridad. Revisar el acto y su ámbito antes de concluir aplicabilidad.	https://www.congreso.gob.gt/detalle_pdf/decretos/13076

Criterios de uso

CRITERIOS PARA UTILIZAR LAS REFERENCIAS	
1. Diferenciar ley y marco	La Constitución y los decretos son referencias jurídicas. ITAF, COBIT, ISO, NIST y OWASP son marcos, normas técnicas o guías; no deben presentarse como leyes guatemaltecas.
3. Protección de datos en Guatemala	No describir el Decreto 57-2008 como una ley general aplicable automáticamente a toda empresa privada. Su ámbito se relaciona con sujetos obligados. Para RedNova, confirmar primero si encaja en los supuestos legales.
4. No afirmar incumplimientos sin evidencia	La matriz sirve para orientar criterios y pruebas. Solo registrar incumplimiento cuando exista requisito aplicable, evidencia suficiente y evaluación documentada.
5. Versiones	Se han indicado versiones identificadas en las fuentes oficiales consultadas al 04/11/2026. Verificar nuevamente antes de entregar el informe final.
Actualización documental	Revisión del 08/11/2026 con los documentos del expediente disponibles. La matriz conserva referencias técnicas y jurídicas como criterios orientadores; su inclusión no prueba aplicabilidad legal, certificación ni incumplimiento. Se ajustó la referencia general de riesgos a R-01–R-14 conforme a la matriz del proyecto. Las pruebas relacionadas continúan diseñadas y no ejecutadas salvo evidencia de ejecución documentada.

Vinculación R-T-E-PT

Referencia / tema	Riesgo relacionado	Prueba diseñada	Evidencia / PT	Aplicación al caso y límite
ITAF 5.ª edición	R-01 a R-14 según alcance	T-01 a T-15 (diseñadas; no ejecutadas)	E-01 a E-10; PT-01 a PT-10	Guía de documentación y evidencia suficiente; no implica certificación ni hallazgo.
COBIT 2019	R-05; R-06; R-08; R-10; R-15	T-05; T-06; T-08; T-10; T-15	E-06; E-08; E-09; PT-06; PT-08; PT-09	Gobierno, cambios, terceros y continuidad; controles aún por probar.
NIST CSF 2.0	R-01 a R-14	T-01 a T-15	E-01 a E-10; PT-01 a PT-10	Ordena GOVERN/IDENTIFY/PROTECT/DETECT/RESPOND/RECOVER; pruebas diseñadas, no ejecutadas.
NIST SP 800-61 Rev. 3	R-09; R-11; R-15; además respuesta/recuperación	T-09; T-11; T-15; T-08/T-10	E-07; E-08; PT-07; PT-08	Respuesta, escalamiento, preservación y recuperación; cronología continúa preliminar.
OWASP Top 10:2025	R-03; R-04; R-05; R-13	T-03; T-04; T-05; T-13	E-01; E-02; E-05; E-06; PT-02; PT-05; PT-06	Orientación para autenticación, autorización, cambios e integridad; no sustituye pruebas técnicas.
NIST AI RMF 1.0 / AI 600-1	R-14	T-14	E-10; PT-10	T-14 propone 20 casos ficticios en sandbox; aún no ejecutada. 0.08 no interpretable sin escala.
Constitución de Guatemala, art. 24	R-07; R-12 (si se revisan comunicaciones/documentos)	T-07; T-12	E-03; E-04; PT-03; PT-04	Aplicación depende de hechos, autorización y procedimiento; no concluir vulneración.
Decreto 57-2008 (LAIP)	R-07 (solo si RedNova encaja como sujeto obligado)	T-07	E-03; E-04; PT-03; PT-04	Confirmar naturaleza jurídica y supuesto legal antes de afirmar aplicabilidad.
Decreto 47-2008	R-05; R-13, para aprobaciones/transacciones electrónicas según ámbito	T-05; T-13	E-05; E-06; PT-05; PT-06	Verificar autenticidad e integridad de documentos/firma; no es ley general de privacidad o ciberseguridad.